

Continuous Control Assurance Framework (CCAF)

A Nonproprietary Synthetic Demonstration for Financial and Digital-Payment Environments

Ayodele Timothy Adeniyi, CISA, ACA
Version 1.3.1 | July 16, 2026 | Apache License 2.0

Purpose. CCAF is a vendor-neutral reference implementation that converts selected access, change-management, logging, reconciliation, and payment-monitoring objectives into repeatable control tests. It evaluates supplied in-scope records, identifies conditions for review, reports explicit evaluation status and eligible populations, and preserves artifacts needed to reproduce a run. This PDF summarizes the release; the detailed methodology and work-program procedures remain in the repository.

What the package contains

Working analytics	Twenty versioned control tests across privileged access, change/logging, and reconciliation/payment modules.
Reproducible evidence	Synthetic data with planted conditions, source-assurance record, SHA-256 manifest, run metadata, calibration record, and regression tests.
Transfer materials	Control-test catalog, configurable thresholds, reference SQL, implementation checklist, governance guidance, and framework traceability with interpretive boundaries.

Evidence boundaries

- The repository contains seeded synthetic data and independently written documentation and code; no employer, client, or production material was used.
- All results describe the fixed synthetic demonstration: full-population means every row of the supplied in-scope extract, and detection of planted conditions is regression evidence, not a production accuracy rate.
- The 20 tests are a bounded reference set, not a comprehensive catalog, and complement rather than replace enterprise security, GRC, and audit platforms.
- No institutional adoption, external validation, or endorsement by any referenced organization is claimed.

20	9	20,300	168
control tests	source datasets (SHA-256 manifest)	eligible control evaluations	reported exceptions

1. Architecture and Control Coverage

1. Validate	2. Evaluate	3. Report	4. Preserve
Schemas, keys, timestamps, and selected relationships	Rule-based tests and peer-comparison screens	Structured exception records and per-control eligible populations	Hashes, configuration, calibration status, and run metadata

Blocking Critical or High source-data findings stop execution. Each test reports Completed or Not Evaluable, the population actually eligible for the procedure, and any resulting exceptions. A Not Evaluable test cannot appear as a clean result, and the framework does not assign synthetic module risk tiers.

ID	Control test	Eligible population	Review priority
PA-01	Terminated user retains active privileged access	Terminated users with active privileged grants	Critical
PA-02	Privileged grant lacks approver	Active privileged grants	High
PA-03	Self-approved access grant	Active grants	High
PA-04	Dormant privileged account	Active privileged users (extract must cover the dormancy period)	Medium
PA-05	Toxic entitlement pair	Users with active grants	Critical
PA-06	After-hours authentication outlier	Users meeting peer-comparison preconditions	Medium
PA-07	Expired temporary privileged access	Active temporary privileged grants	Critical
CM-01	Implemented change lacks approval	Implemented changes	High
CM-02	Approver also implements change	Implemented changes	High
CM-03	Emergency change lacks review	Emergency changes	Medium
CM-04	Deployment lacks valid change record	Deployment events	Critical
CM-05	Log source exceeds heartbeat	Log sources	High
CM-06	Emergency-change rate spike	Portfolio comparison	Medium
CM-07	Implemented change lacks test evidence	Implemented changes	High
TR-01	Ledger item lacks processor match	Ledger records past the settlement grace period	High
TR-02	Ledger/processor amount difference	Matched records	High
TR-03	Duplicate transaction identifier	Unique transaction IDs	Critical
TR-04	Aged unreconciled item	Unreconciled ledger records	Medium
TR-05	Transaction-velocity outlier	Accounts meeting peer-comparison preconditions	Medium
TR-06	Threshold hovering below approval limit	Accounts in ledger	High

Detection and interpretation

Rule-based tests identify records that meet a defined review condition. Peer-comparison screens compare a user or account with the relevant population and flag observations far outside the typical range; the technical implementation uses a robust z-score based on the median and median absolute deviation so a small number of extreme values do not distort the baseline. Every exception is a lead for investigation, not a confirmed control deviation, deficiency, intent, or culpability. Bundled thresholds are demonstration defaults stored in `config/defaults.json`.

2. Validation and Transparent Reporting

The generator plants and labels 165 known test conditions. Automated regression tests detected 165 of 165 planted conditions across all 20 control tests in this fixed synthetic scenario. The run also reported 3 additional peer-comparison observations. Because ordinary synthetic background records can satisfy a comparison rule, those observations require review and are not automatically classified as errors or false positives.

Module	Planted	Detected	Detected %	Additional observations
Privileged Access	39	39	100%	1
Change and Logging	49	49	100%	0
Reconciliation and Payments	77	77	100%	2

Population reporting

Each test reports exceptions per 1,000 eligible records or entities. Module summaries add the eligible populations of only Completed tests and report exceptions per 1,000 eligible evaluations. These rates provide review context; they are not incident rates, error rates, or institution-level risk ratings.

Module	Total	Completed	Not eval.	Evaluations	Exceptions	Per 1,000
M1 Privileged Access	7	7	0	2,120	40	18.87
M2 Change & Logging	7	7	0	1,654	49	29.63
M3 Reconciliation & Payments	6	6	0	16,526	79	4.78

Demonstration outputs

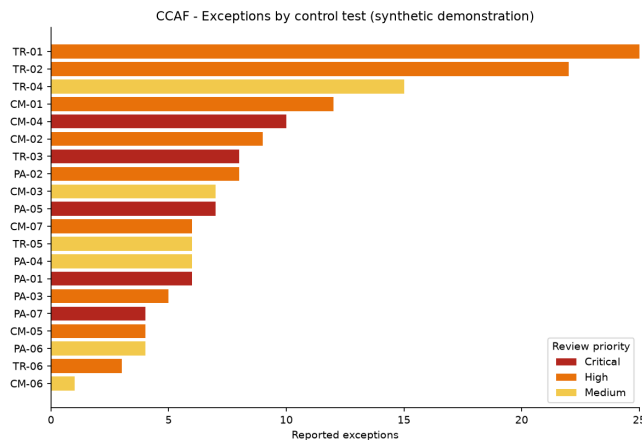


Figure 1. Exceptions by control and review priority.

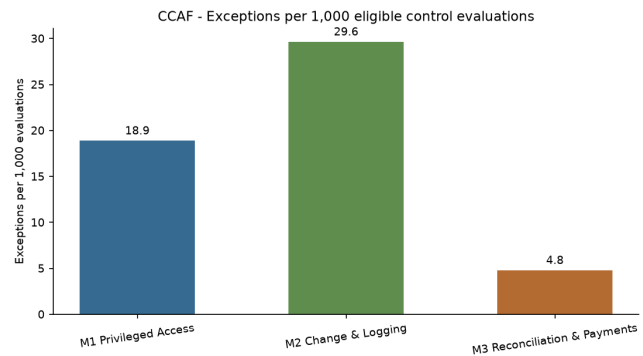


Figure 2. Exceptions per 1,000 eligible control evaluations.

Review-priority score

Review-priority score = configurable review-priority weight x exposure factor (1.0-2.0). It orders follow-up work within the demonstration. It is not a loss probability, compliance rating, confirmed deficiency, or empirically calibrated risk score.

3. Implementation, Governance, and Traceability

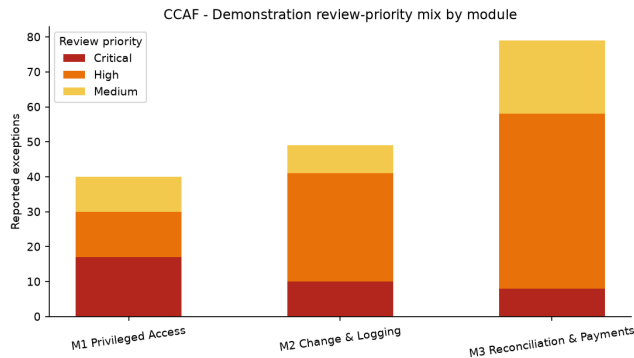


Figure 3. Review-priority mix by module.

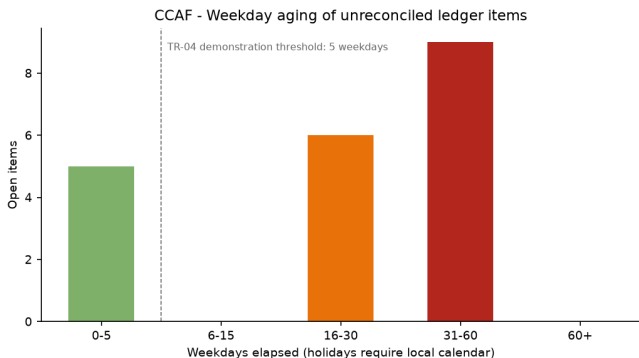


Figure 4. Weekday aging; production requires an approved holiday calendar.

Control-assurance lifecycle

A production conclusion requires more than exception analytics. Teams document control scope and design, configuration and implementation, whether source records are complete and accurate for the procedure, operation across the period, exception disposition, and whether later changes could affect consistent operation since testing.

Phased implementation

Phase	Required work
0 - Authorize	Approve scope, data access, schemas, thresholds, calendars, review-priority definitions, and escalation.
1 - Pilot	Inspect authorized historical records, inquire regarding each exception, determine its disposition, assess reviewer effort, and calibrate.
2 - Operationalize	Schedule authorized runs, integrate ticketing/GRC, apply retention and access controls, and monitor drift.
3 - Govern	Obtain required approvals, train a second operator, revalidate after changes, and contribute only nonconfidential improvements.

Framework traceability

Module	Primary relevance	Interpretive boundary
Privileged Access	NIST CSF PR.AA/GV.RR; FFIEC access administration; PCI DSS 7/8/10	Supports evidence organization; does not establish compliance.
Change and Logging	NIST CSF PR.PS/DE.CM/DE.AE; FFIEC development and operations; PCI DSS 6/10	Test outputs require institutional scope and adjudication.
Reconciliation and Payments	FFIEC payment-system reconciliation and integrity topics; supporting NIST detection relationships	NIST/PCI entries are supporting relationships, not direct reconciliation requirements.

Governance artifacts

A successful run creates the input hash manifest, source-assurance record, data-quality report, structured exception records, per-test evaluation summaries, calibration record, run metadata, and planted-condition verification summary. The demonstration leaves independent row-count and control-total reconciliation unresolved for all 9 datasets. Adopting institutions must complete those fields, define retention and remediation requirements, and preserve exception dispositions.

4. Limitations, References, and Release Status

Limitations

- Synthetic verification demonstrates software behavior only for the fixed planted scenario; it does not establish production accuracy, adoption, or loss reduction.
- Source-extract completeness, field mapping, privacy, holiday calendars, expected activity, and thresholds must be validated locally; file hashes alone do not establish completeness.
- The framework is not a complete cybersecurity, fraud, anti-money-laundering, audit, or compliance program.
- Reference SQL uses database-dependent boolean, interval, and timestamp patterns and must be adapted and tested on the target platform.
- No agency, standards body, employer, client, examiner, or independent reviewer is represented as endorsing this version.

Authoritative references

1. NIST, **The Cybersecurity Framework (CSF) 2.0**, NIST CSWP 29 (2024), <https://doi.org/10.6028/NIST.CSWP.29>.
2. NIST, **Information Security Continuous Monitoring**, SP 800-137 (2011), <https://doi.org/10.6028/NIST.SP.800-137>.
3. FFIEC, **Cybersecurity Assessment Tool Sunset**, <https://www.ffiec.gov/cyberassessmenttool.htm>. FFIEC states that it does not endorse a particular replacement tool.
4. FFIEC, **Information Technology Examination Handbook InfoBase**, <https://ithandbook.ffiec.gov/>.
5. PCI Security Standards Council, **PCI DSS v4.x**, <https://www.pcisecuritystandards.org/standards/pci-dss/>.
6. U.S. Securities and Exchange Commission, rules implementing Sarbanes-Oxley Act Section 404 internal-control reporting requirements.
7. The Institute of Internal Auditors, **GTAG: Continuous Auditing and Monitoring, 3rd Edition** (2025), <https://www.theiia.org/en/content/guidance/recommended/supplemental/gtags/continuous-auditing-and-monitoring>.

Repository package

The package includes source code, planted-condition data and labels, JSON configuration, a source-metadata template, automated tests, reference SQL, source-assurance and run artifacts, generated exceptions and summaries, dashboards, a 20-test practitioner catalog, governance and implementation documents, Apache-2.0 license, changelog, version file, and citation metadata. This release summary is reproducible from `scripts/build_methodology_pdf.py`; the detailed method is documented in `docs/methodology.md`.

Release status: Version 1.3.1 is a maintenance release prepared on July 16, 2026, superseding version 1.3.0. Repository: <https://github.com/Ayodele-Adeniyi/continuous-control-assurance-framework>. Version tag: <https://github.com/Ayodele-Adeniyi/continuous-control-assurance-framework/tree/v1.3.1>. SHA-256 of `docs/methodology.md`: 540c3d8f6b1376a5bd54926972c02dcda483923b615ab5994b5f049842d5b0df. No institutional adoption, agency endorsement, or external validation is claimed.